

Relatório de Verificação de Segurança — Plataforma de Precificação de Seminovos (SDP #5211)

Data: 20/08/2026 · Ambiente: mock local de demonstração — frontend React/Vite (dev server, <http://localhost:5173>) e API FastAPI 100% mockada (<http://localhost:8010>) · Método: testes E2E automatizados (Playwright/Chromium) + auditoria de dependências

Escopo e limitações — leia antes de usar este relatório.

- Verificação **automatizada** de segurança sobre uma aplicação **mockada**, executando em **ambiente de desenvolvimento local** (Vite dev server + Uvicorn). Nenhum resultado aqui representa a postura de segurança de um ambiente de produção.
- Não é um pentest profissional**: não cobre infraestrutura, rede, nuvem (AWS/Snowflake), engenharia social, nem análise manual aprofundada de lógica de negócio.
- A aplicação **não possui autenticação por design** (mock de demonstração da Fase 6, Alternativa A) — autenticação/autorização estão **fora de escopo** desta verificação e são obrigatórias antes de qualquer exposição real.
- Superfície testada: painel analítico (4 jornadas), inputs de busca/filtros, 4 endpoints da API mock, CORS, cabeçalhos HTTP e dependências declaradas.

1. Jornadas E2E executadas

Executadas em Chromium *headed* com câmera lenta (3 s por ação) para acompanhamento visual. Suíte em `e2e/tests/jornadas.spec.ts`; cada teste é independente e somente leitura (aplicação sem mutação de estado — nada a preparar ou limpar).

Jornada	O que foi verificado	Resultado
A — Visão executiva	Carga do painel; 3 KPIs (veículos no inventário, preço recomendado médio, com alerta/não avaliados); gráficos executivos por classe e por canal; gráfico "Recomendado vs. FIPE — últimos 4 meses"; tabela de inventário populada. Console sem erros.	PASSOU
B — Busca e detalhe	Busca por placa parcial "BRA" (RF-F6-A-02); abertura do offcanvas do veículo BRA2E19 com seções Precificação, Percentis de mercado (faixas), Comparáveis, Classificação e canal e Histórico; fechamento do painel. Console sem erros.	PASSOU
C — Classe "Não avaliado"	Filtro de classe <code>NAO_AVALIADO</code> ; veículo XLM8E67 (avaria nula) exibido como "Não avaliado" e nunca como Classe A — regra da spec "avaria nula não é zero" respeitada na UI e na API. Console sem erros.	PASSOU
D — Exportação CSV	Download <code>inventario-precificacao-2026-08-20.csv</code> com cabeçalho, separador ";" e dados do inventário filtrado (RF-F6-A-10). Console sem erros.	PASSOU

2. Verificações de segurança

Suíte em `e2e/tests/seguranca.spec.ts` (8 testes, todos executados). Resultados reais observados:

Checagem	Resultado	Evidência resumida
XSS nos inputs do painel (busca por placa)	SEM FALHA	Payloads <code><script></code> , <code>"><img onerror=</code> e quebra de aspas digitados na busca: nada executou (sem <code>alert</code> , sem <code>window.__xss</code>), nenhum nó injetado no DOM. React escapa a saída; conteúdo aparece apenas como texto no estado vazio.
Validação de entrada da API (query params malformados e payloads de injeção)	SEM FALHA	placa com payload XSS (>7 chars), ano=DROP TABLE..., classe=A' OR '1'='1, page=-1, page_size=99999 → todos 400 com envelope padronizado <code>{"error": {"code,message,details}}</code> (padrão api-land). Sem stack trace, sem caminhos de arquivo, sem detalhes internos.
Path traversal na rota de placa	SEM FALHA	<code>/api/inventario/..%2F..%2Fetc%2Fpasswd</code> e variantes → 404/400 no envelope padrão; nenhum conteúdo de arquivo ou vazamento.
Recurso inexistente	SEM FALHA	GET <code>/api/inventario/ZZZ9Z99</code> → 404 com <code>error.code</code> / <code>error.message</code> , sem detalhe interno.

Checagem	Resultado	Evidência resumida
Contrato de resposta sem campos inesperados/sensíveis	SEM FALHA	Chaves do inventário conferidas campo a campo contra o contrato esperado; nenhum campo extra ou sensível na resposta.
CORS restrito à origem do painel	SEM FALHA	Origem http://localhost:5173 → permitida; origem maliciosa → sem Access-Control-Allow-Origin (inclusive no preflight OPTIONS). Allowlist explícita em backend/app/main.py .
Console do navegador nas 4 jornadas	SEM FALHA	Nenhum erro de console ou pageerror ; nenhum dado sensível logado.
Cabeçalhos de segurança (dev server)	INFORMATIVO	Vite e API sem CSP, X-Content-Type-Options , X-Frame-Options , HSTS ou Referrer-Policy ; API expõe Server: uvicorn . Sem X-Powered-By em ambos. Servidor de desenvolvimento não representa produção — ver achados I-1/I-2.
Dependências do frontend — npm audit --omit=dev	0 VULNS	Dependências de produção (react 19.2.8, react-dom 19.2.8): 0 vulnerabilidades conhecidas.
Dependências do backend — pip-audit sobre requirements.txt	10 AVISOS	10 vulnerabilidades conhecidas em 4 pacotes (starlette 0.46.2 ×7, click 8.1.8, python-dotenv 1.2.1, pytest 8.3.5). Detalhamento na seção 3.

3. Achados

Nenhuma vulnerabilidade **explorável na aplicação** foi encontrada no escopo testado (XSS, injeção via API, path traversal, CORS, vazamento de erro). A auditoria de dependências e a revisão dos cabeçalhos, porém, produziram os achados abaixo — **o relatório os registra integralmente**:

3.1 Dependências do backend com CVEs conhecidos (pip-audit)

Pacote	Advisories	Severidade*	Contexto neste app e recomendação
starlette 0.46.2 (runtime, base do FastAPI)	PYSEC-2026-161, -248, -249, -1941, -1942, -2280, -2281	Média	Advisories cobrem DoS via header <code>Range</code> em <code>FileResponse</code> , limites de multipart não aplicados, reconstrução de URL sem validar <code>Host</code> , SSRF em <code>StaticFiles</code> (Windows) e dispatch de método em <code>HTTPEndpoint</code> . A API mock atual (JSON puro, sem upload, sem <code>FileResponse</code> / <code>StaticFiles</code>) <i>não exercita</i> os vetores principais, mas o pacote roda em produção do framework. Recomendação: atualizar FastAPI/starlette para versão com correções (starlette ≥ 1.3.1) antes de qualquer evolução além do mock.
click 8.1.8 (transitivo, via uvicorn)	PYSEC-2026-2132	Baixa	Injeção de comando em <code>click.edit()</code> — função não utilizada pelo app. Recomendação: subir para ≥ 8.3.3 na próxima atualização de dependências.
python-dotenv 1.2.1 (transitivo, via uvicorn)	PYSEC-2026-2270	Baixa	<code>set_key()</code> / <code>unset_key()</code> seguem symlink ao reescrever <code>.env</code> — app apenas lê variáveis. Recomendação: subir para ≥ 1.2.2.
pytest 8.3.5 (dependência de teste)	PYSEC-2026-1845	Baixa	DoS/escalação local via diretórios previsíveis em <code>/tmp</code> em máquinas UNIX compartilhadas; só afeta ambiente de desenvolvimento. Recomendação: subir para ≥ 9.0.3.

* Severidade avaliada no contexto deste app mockado local; em produção a exposição de starlette deve ser reavaliada.

3.2 Observações informativas e de hardening

ID	Severidade	Observação e recomendação
I-1	Informativa	Cabeçalhos de segurança ausentes (CSP, <code>X-Content-Type-Options</code> , <code>X-Frame-Options</code> , HSTS, <code>Referrer-Policy</code>) no Vite dev server e na API. Esperado em ambiente de desenvolvimento; para produção, servir o build atrás de um edge/proxy que aplique esses cabeçalhos.
I-2	Informativa	API expõe Server: <code>uvicorn</code> — divulgação menor de tecnologia. Em produção, suprimir/normalizar o header no proxy reverso.
H-1	Baixa (hardening)	Exportação CSV sem neutralização de fórmulas: <code>frontend/src/utils/csv.ts</code> escapa aspas/separadores, mas não prefixa campos iniciados por <code>=</code> , <code>+</code> , <code>-</code> ou <code>@</code> (CSV/fórmula injection ao abrir no Excel). Não explorável com o mock atual (dados controlados), mas os dados reais virão de fornecedores externos de anúncios — recomenda-se neutralizar antes da integração real. <i>Reportado sem alteração de código, conforme o processo.</i>

4. Conclusão

No escopo testado — jornadas do painel, inputs de busca/filtros, 4 endpoints da API mock, CORS e tratamento de erros — **nenhuma vulnerabilidade explorável foi encontrada na aplicação**: os payloads de XSS e injeção foram neutralizados pelo escape do React e pela validação de tipos/limites da API, os erros seguem envelope padronizado sem vazamento interno e o CORS restringe corretamente a origem.

O relatório, contudo, não é "zero achados": a auditoria de dependências identificou **10 vulnerabilidades conhecidas em 4 pacotes do backend** (severidade média no starlette 0.46.2; baixa nos demais, com vetores não exercitados pelo mock) e 3 observações informativas/de hardening (I-1, I-2, H-1). Recomenda-se atualizar as dependências apontadas e aplicar os itens de hardening antes de qualquer evolução do mock para ambiente real.

Reforço final: verificação automatizada em aplicação mockada e ambiente local de desenvolvimento, sem autenticação por design – não substitui pentest profissional nem avaliação de infraestrutura/produção.

5. Evidências das jornadas

Capturas geradas pela execução em e2e/evidencias/ (arquivos completos no repositório).

Pricing - Plate-by-Plate Pricing

Pricing / Used Vehicles / Plate-by-Plate Pricing

20
Veículos no inventário

R\$ 159.545,00
Preço recomendado médio

5
Com alerta ou não avaliados

Composição por classe comercial

Veículos do resultado filtrado por classe A-E; avaliação pendente é parte.

Classe A

Classe B

Classe C

Classe D

Classe E

Não avaliado

1
0
5
2
2
1

Valor recomendado por canal

Soma do preço recomendado dos veículos filtrados, por canal sugerido.

R\$ 3.186.900,00

VALOR TOTAL RECOMENDADO

Retail: 13 veículos R\$ 1.963.000,00 - 63%

Wholesale: 7 veículos R\$ 1.011.800,00 - 32%

Não definido: 1 veículo R\$ 218.600,00 - 7%

Recomendado vs. FIPE — últimos 4 meses

Preço recomendado médio do portfólio contra o valor FIPE médio. Dados ilustrativos (mock) — o série real virá da camada Gold.

R\$ 120.000

R\$ 114.000

R\$ 108.000

jun

jul

ago

FIPE média

Recomendado

Preço recomendado médio: R\$ 109.900 -1,7% no período mai-ago FIPE média: R\$ 115.900 -1,3% no período mai-ago
Eixo iniciado em R\$ 106.000 (parte desalinhada para evidenciar a variação mensal).

Procurar por placa

Modelo

Versão

Ano

Classe

Canal

Ex.: BRAZE19

Todos

Todas

Todos

Todas

Todos

Limpar filtros

Exportar CSV

Plate-by-Plate Pricing

Plataforma de Precificação de Seminovos — Inventário e recomendações

30 veículos encontrados

PLACA	MODELO	VERSÃO	ANO	KM	CLASSE	CANAL SUGERIDO	PREÇO RECOMENDADO	CONFIANÇA	ALERTA
BRAZE19	Toyota Corolla	XEI 2.0 Flex Aut.	2022	58.000 km	Classe A	Retail	R\$ 124.700,00	Alta (95)	—
FZCSD28	Toyota Corolla	Altis Premium Hybrid	2025	24.000 km	Classe A	Retail	R\$ 137.300,00	Alta (95)	—
GHTB47	Toyota Corolla	GLi 1.8 Flex	2021	74.000 km	Classe B	Retail	R\$ 106.000,00	Alta (95)	—
KNTSE60	Toyota Corolla Cross	XRE 2.0 Flex	2022	62.000 km	Classe B	Retail	R\$ 139.800,00	Alta (95)	—
PXV9A12	Toyota Corolla Cross	XRX Hybrid	2023	30.000 km	Classe B	Retail	R\$ 173.700,00	Alta (95)	—
QRA7B45	Toyota Hilux	SRX 4x4 Diesel Aut.	2022	88.000 km	Classe C	Wholesale	R\$ 255.200,00	Alta (95)	—
RTK4C09	Toyota Hilux	SRV 4x4 Diesel	2021	118.000 km	Classe C	Wholesale	R\$ 223.200,00	Alta (95)	—
SBK8D73	Toyota Hilux	SR 4x2 Diesel	2020	105.000 km	Classe D	Wholesale	R\$ 172.200,00	Alta (95)	—
THAE56	Toyota Yaris	XL 1.5 Aut.	2022	52.000 km	Classe B	Retail	R\$ 94.500,00	Alta (95)	—
UYSA638	Toyota Yaris	XL 1.5 Aut.	2021	58.000 km	Classe B	Retail	R\$ 82.500,00	Alta (95)	—
VDF5B91	Toyota Siiv4	SRX Diamond 7L Diesel	2023	21.000 km	Classe A	Retail	R\$ 305.600,00	Baixa (40)	⚠
WKSC24	Toyota Siiv4	SRX 7L Diesel	2021	96.000 km	Classe B	Retail	R\$ 316.200,00	Alta (95)	—
XLME67	Toyota RAV4	SX Hybrid AWD	2021	67.000 km	Não avaliado	Não definido	R\$ 213.600,00	Baixa (35)	⚠
YNP2A85	Honda Civic	Touring 1.5 Turbo	2020	89.000 km	Classe C	Wholesale	R\$ 115.600,00	Alta (95)	—
ZQE7D13	Jeep Compass	Longitude T270 Flex	2022	47.000 km	Classe B	Retail	R\$ 129.800,00	Média (75)	⚠
BSV4E52	Volkswagen T-Cross	Highline 1.4 TSI	2025	33.000 km	Classe B	Retail	R\$ 131.300,00	Alta (95)	—
CJW8B76	Chevrolet Onix	Premier 1.0 Turbo	2022	45.000 km	Classe C	Wholesale	R\$ 84.000,00	Média (95)	⚠
DKW6C31	Hyundai HB20S	Platinum 1.0 TGD1	2023	41.000 km	Classe E	Wholesale	R\$ 74.700,00	Alta (95)	—
EPLA98	Fiat Toro	Volcano 2.0 Diesel 4x4	2022	76.000 km	Classe B	Retail	R\$ 140.600,00	Baixa (40)	⚠
FMS3D44	Renault Duster	Iconic 1.6 CVT	2021	85.000 km	Classe D	Wholesale	R\$ 86.400,00	Alta (95)	—

Copyright © 2026 KINTO Brasil - NPMG Admin. All rights reserved.

Jornada A — KPIs, gráficos por classe/canal e "Recomendado vs. FIPE" (jornada-a-painel.png)

Pricing - Plate-by-Plate Pricing

Pricing / Used Vehicles / Plate-by-Plate Pricing

R\$ 123.500

R\$ 114.500

R\$ 105.500

jun

jul

ago

FIPE média

Recomendado

Preço recomendado médio: R\$ 109.900 -1,7% no período mai-ago FIPE média: R\$ 115.900 -1,3% no período mai-ago
Eixo iniciado em R\$ 106.000 (parte desalinhada para evidenciar a variação mensal).

Procurar por placa

Modelo

Versão

Ano

Classe

Canal

BRA

Todos

Todas

Todos

Todos

Todos

Limpar filtros

Exportar CSV

Plate-by-Plate Pricing

Plataforma de Precificação de Seminovos — Inventário e recomendações

30 veículos encontrados

PLACA	MODELO	VERSÃO	ANO	KM	CLASSE	CANAL SUGERIDO	PREÇO RECOMENDADO	CONFIANÇA	ALERTA
BRAZE19	Toyota Corolla	XEI 2.0 Flex Aut.	2022	58.000 km	Classe A	Retail	R\$ 124.700,00	Alta (95)	—

Copyright © 2026 KINTO Brasil - NPMG Admin. All rights reserved.

Precificação

PREÇO RECOMENDADO

R\$ 124.700,00

FAIXA OPERACIONAL

R\$ 122.000,00 - R\$ 127.400,00

FAIXA CONSERVADORA

R\$ 123.200,00 - R\$ 126.200,00

REFERÊNCIA INTERNA (BUTIMADA)

R\$ 122.000,00

REFERÊNCIA EXTERNA (DESCARDO)

R\$ 126.500,00

DATA DE REFERÊNCIA DO MERCADO

16/06/2026

Porcentagem de mercado

PIB

PIS

PIB

PIS

PIB

R\$ 119.700,00

R\$ 122.000,00

R\$ 124.700,00

R\$ 127.400,00

R\$ 129.700,00

Confiância e qualidade de dados

Nível de confiança

Alta (95)

Classificação e canal

CLASSE

Classe A

CANAL SUGERIDO

Retail

REGRA APLICADA

Classe A — inventário igual a R\$ 0 e a KM médio anual e 10.000 km

EXCEÇÃO POSSÍVEL

Não

HATCHING

Corolla XEI 2.0 Flex Aut. — nível 1 (Nível 1 — código FIPE idêntico)

Fuores da recomendação

Jornada B — detalhe do BRAZE19: precificação, faixas e comparáveis (jornada-b-detalhe.png)

Pricing - Plate-by-Plate Pricing

Pricing / Used Vehicles / Plate-by-Plate Pricing

1
Veículos no inventário

R\$ 213.600,00
Preço recomendado médio

1
Com alerta ou não avaliados

Composição por classe comercial

Veículos do resultado filtrado por classe A-E; avaliação pendente é parte.

Classe A

Classe B

Classe C

Classe D

Classe E

Não avaliado

0
0
0
0
0
1

Valor recomendado por canal

Soma do preço recomendado dos veículos filtrados, por canal sugerido.

R\$ 213.600,00

VALOR TOTAL RECOMENDADO

Retail: 0 veículos R\$ 0,00 - 0%

Wholesale: 0 veículos R\$ 0,00 - 0%

Não definido: 1 veículo R\$ 213.600,00 - 100%

Recomendado vs. FIPE — últimos 4 meses

Preço recomendado médio do portfólio contra o valor FIPE médio. Dados ilustrativos (mock) — o série real virá da camada Gold.

R\$ 120.000

R\$ 114.000

R\$ 108.000

jun

jul

ago

FIPE média

Recomendado

Preço recomendado médio: R\$ 109.900 -1,7% no período mai-ago FIPE média: R\$ 115.900 -1,3% no período mai-ago
Eixo iniciado em R\$ 106.000 (parte desalinhada para evidenciar a variação mensal).

Procurar por placa

Modelo

Versão

Ano

Classe

Canal

Ex.: BRAZE19

Todos

Todas

Todos

Não avaliado

Todos

Limpar filtros

Exportar CSV

Plate-by-Plate Pricing

Plataforma de Precificação de Seminovos — Inventário e recomendações

1 veículo encontrado

PLACA	MODELO	VERSÃO	ANO	KM	CLASSE	CANAL SUGERIDO	PREÇO RECOMENDADO	CONFIANÇA	ALERTA
XLME67	Toyota RAV4	SX Hybrid AWD	2021	67.000 km	Não avaliado	Não definido	R\$ 213.600,00	Baixa (35)	⚠

Copyright © 2026 KINTO Brasil - NPMG Admin. All rights reserved.

Jornada C — XLM8E67 como "Não avaliado", nunca Classe A (jornada-c-nao-avaliado.png)

Pricing - Plate-by-Plate Pricing

Pricing / Used Vehicles / Plate-by-Plate Pricing

R\$ 104.500

R\$ 105.500

R\$ 106.500

jun

jul

ago

FIPE média

Recomendado

Preço recomendado médio: R\$ 109.900 -1,7% no período mai-ago FIPE média: R\$ 115.900 -1,3% no período mai-ago
Eixo iniciado em R\$ 106.000 (parte desalinhada para evidenciar a variação mensal).

Procurar por placa

Modelo

Versão

Ano

Classe

Canal

Ex.: BRAZE19

Todos

Todas

Todos

Todos

Todos

Limpar filtros

Exportar CSV

Plate-by-Plate Pricing

Plataforma de Precificação de Seminovos — Inventário e recomendações

30 veículos encontrados

PLACA	MODELO	VERSÃO	ANO	KM	CLASSE	CANAL SUGERIDO	PREÇO RECOMENDADO	CONFIANÇA	ALERTA
BRAZE19	Toyota Corolla	XEI 2.0 Flex Aut.	2022	58.000 km	Classe A	Retail	R\$ 124.700,00	Alta (95)	—
FZCSD28	Toyota Corolla	Altis Premium Hybrid	2025	24.000 km	Classe A	Retail	R\$ 137.300,00	Alta (95)	—
GHTB47	Toyota Corolla	GLi 1.8 Flex	2021	74.000 km	Classe B	Retail	R\$ 106.000,00	Alta (95)	—
KNTSE60	Toyota Corolla Cross	XRE 2.0 Flex	2022	62.000 km	Classe B	Retail	R\$ 139.800,00	Alta (95)	—
PXV9A12	Toyota Corolla Cross	XRX Hybrid	2023	30.000 km	Classe B	Retail	R\$ 173.700,00	Alta (95)	—
QRA7B45	Toyota Hilux	SRX 4x4 Diesel Aut.	2022	88.000 km	Classe C	Wholesale	R\$ 255.200,00	Alta (95)	—
RTK4C09	Toyota Hilux	SRV 4x4 Diesel	2021	118.000 km	Classe C	Wholesale	R\$ 223.200,00	Alta (95)	—
SBK8D73	Toyota Hilux	SR 4x2 Diesel	2020	105.000 km	Classe D	Wholesale	R\$ 172.200,00	Alta (95)	—

Copyright © 2026 KINTO Brasil - NPMG Admin. All rights reserved.

Jornada D — exportação CSV do inventário filtrado (jornada-d-export-csv.png)

